

BIMA Audit Summary

Prepared by Cyfrin

Version 2.0

Lead Auditors

Dacian

September 27, 2024

Contents

1 About Cyfrin 2

2 About This Document 2

3 Disclaimer 2

4 Copyright and License 2

5 Audit Overview 3

6 Audit Scope 3

7 Risk Classification 4

8 Protocol Summary 5

9 Attestation 5

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for BIMA on BIMA. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number and final status of findings by severity. It closes with Cyfrin's attestation of the review's scope and final remediation status.

It is deliberately abbreviated: the technical detail of individual findings is not reproduced here. The complete audit report, version 2.0 dated September 27, 2024, was delivered to BIMA, who retain it as the full record of the engagement. This summary was issued on October 29, 2026.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from BIMA or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 28 days, the Cyfrin team conducted an audit on the BIMA code provided by BIMA. The findings consist of 4 High, 9 Medium & 17 Low severity issues with the remainder being informational and gas optimizations.

Summary

Project Name	BIMA
Repository	bima-v1-core
Commit	ec35b0a360f5...
Audit Timeline	Aug 15th - Sep 23rd, 2024
Methods	Manual Review, Stateless Fuzzing

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	0	0	0
High Risk	4	4	0
Medium Risk	9	6	3
Low Risk	17	16	1
Informational	18	17	1
Gas Optimizations	15	15	0
Total	63	58	5

6 Audit Scope

The audit was started on commit 09461f0d22556e810295b12a6d7bc5c0efec4627, and our internal repository was based on PR39. In later commit 0d35af44924e9cf69dfd7d06936396c42b6e57c9 a new contract `StorkOracleWrapper` was added which also became part of the audit scope.

The following contracts within the `contracts` folder together with associated interfaces in the `interfaces` folder and external dependencies were included in the scope for this audit:

```
core/helpers/MultiCollateralHintHelpers.sol
core/helpers/MultiTroveGetter.sol
core/helpers/TroveManagerGetters.sol
core/BabelCore.sol
core/BorrowerOperations.sol
core/DebtToken.sol
core/Factory.sol
core/GasPool.sol
core/LiquidationManager.sol
core/PriceFeed.sol
core/SortedTroves.sol
core/StabilityPool.sol
core/StorkOracleWrapper.sol
core/TroveManager.sol
dao/AdminVoting.sol
dao/AirdropDistributor.sol
dao/AllocationVesting.sol
dao/BoostCalculator.sol
dao/EmissionSchedule.sol
dao/FeeReceiver.sol
dao/IncentiveVoting.sol
dao/InterimAdmin.sol
dao/PrismaToken.sol
dao/TokenLocker.sol
dao/Vault.sol
dependencies/BabelBase.sol
dependencies/BabelMath.sol
dependencies/BabelOwnable.sol
dependencies/DelegatedOps.sol
dependencies/SystemStart.sol
staking/Convex/ConvexDepositFactory.sol
staking/Convex/ConvexDepositToken.sol
staking/Curve/CurveDepositFactory.sol
staking/Curve/CurveDepositToken.sol
staking/Curve/CurveProxy.sol
interfaces/*.sol
```

7 Risk Classification

	Impact: High	**Impact: Medium**	**Impact: Low**
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

8 Protocol Summary

BIMA is a Stablecoin protocol backed by Bitcoin Liquid (Re)Staking Tokens (LSTs/LRTs) allowing users to borrow on-chain using their Bitcoin LSTs as collateral. It also features a number of advanced features such as:

- DAO where Bima token holders who lock up their tokens for voting power can create and vote on a wide range of proposals
- highly-configurable emission rewards system which can be used to incentivize user participation with specific parts of the protocol
- liquidation engine integrated with a Stability Pool where liquidity providers can earn rewards from liquidated collateral and the native emission rewards system
- integration with popular platforms such as Curve and Convex

9 Attestation

Cyfrin attests that it performed a security review of the BIMA code provided by BIMA.

The repositories, commits, review period and findings with their final status are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2024-09-27-cyfrin-bima-v2.0.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to BIMA has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=a6c311a6621208083c370007f200cbc8617557e592a8cb3096f129459f0ae1d8
F=2024-09-27-cyfrin-bima-v2.0-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.